

Windows Server & Active Directory

Cette veille porte sur les évolutions de Windows Server et Active Directory, en lien direct avec ma situation E6 (déploiement d'un serveur de fichiers avec AD, GPO et sauvegarde chez TechnoShop via Scalesi).

01 — WINDOWS SERVER 2025

Nouveautés par rapport à Windows Server 2022

Windows Server 2025 est sorti en octobre 2024. Il apporte des améliorations importantes en sécurité et en administration Active Directory :

- **Kerberos armoring (FAST)** activé par défaut — renforce l'authentification des utilisateurs AD (Kerberos est le protocole d'authentification réseau utilisé dans les domaines Windows)
- **SMB over QUIC** — permet l'accès aux partages réseau sans VPN via internet, avec chiffrement intégré (SMB = Server Message Block, le protocole des partages Windows)
- **TLS 1.3** activé par défaut — TLS (Transport Layer Security) est le protocole de chiffrement des communications ; la version 1.3 est la plus sécurisée
- **NTLM désactivable via GPO native** — NTLM est un ancien protocole d'authentification Windows vulnérable aux attaques par relais ; WS2025 facilite sa désactivation

Pour mes missions chez Scalesi, ces évolutions signifient que les migrations futures vers WS2025 apporteront un gain de sécurité significatif sans configuration supplémentaire.

02 — ACTIVE DIRECTORY & GPO

Bonnes pratiques et erreurs à éviter

Active Directory (AD) est l'annuaire centralisé de Windows qui gère les utilisateurs, les ordinateurs et les droits d'accès dans un domaine. Les GPO (Group Policy Objects) sont des règles appliquées automatiquement aux machines et utilisateurs du domaine (politique de mot de passe, blocage USB, mappage de lecteurs...).

- **Comptes inactifs** : les comptes AD sans connexion depuis +90 jours doivent être désactivés — un compte inutilisé est une porte d'entrée potentielle pour un attaquant
- **Principe du moindre privilège** : ne jamais donner plus de droits que nécessaire — éviter de mettre tous les admins dans le groupe "Domain Admins"
- **Politique de mot de passe** : minimum 12 caractères (recommandation NIST 2024), complexité activée, historique des 10 derniers mots de passe — j'ai appliqué cela dans ma situation E6
- **GPO blocage USB** : désactiver les ports USB en écriture pour éviter les fuites de données et les infections par clé malveillante — déployé chez plusieurs clients Scalesi
- **GPO verrouillage écran** : verrouillage automatique après 10 minutes d'inactivité avec mot de passe — pratique simple mais souvent oubliée

03 — SAUVEGARDE WINDOWS SERVER

Windows Server Backup — Forces et limites

Windows Server Backup (WSB) est la solution de sauvegarde native intégrée à Windows Server, gratuite et sans licence supplémentaire. C'est l'outil que j'ai utilisé dans ma situation E6 pour la sauvegarde automatique quotidienne à 02h00 du serveur de fichiers TechnoShop.

✓ Points forts

■ Limites à connaître

Gratuit, inclus dans Windows Server	Pas de sauvegarde incrémentielle fichier
Simple à configurer (GUI ou PowerShell)	Pas d'alerte email native en cas d'échec
Sauvegarde du System State (AD compris)	Pas de console centralisée multi-serveurs
Planification automatique quotidienne	Occupe plus d'espace (pas de déduplication)
Compatible VSS pour cohérence des données	Recommandé pour 1-3 serveurs maximum

Pour des besoins plus avancés (plusieurs serveurs, RPO inférieur à 4h, restauration granulaire d'objets AD), des solutions tierces comme **Veeam Backup & Replication** sont recommandées.

04 — SÉCURITÉ & CVE

Vulnérabilités récentes et correctifs à appliquer

Une **CVE (Common Vulnerabilities and Exposures)** est un identifiant unique attribué à une faille de sécurité découverte dans un logiciel. Chaque CVE reçoit un score **CVSS (Common Vulnerability Scoring System)** de 0 à 10 indiquant sa criticité : 7-8.9 = Élevé, 9-10 = Critique. Le suivi des CVE permet d'appliquer les correctifs prioritaires avant qu'un attaquant ne les exploite.

CVE	Composant	Score	Type d'attaque	Correctif
CVE-2024-38077	Remote Desktop Services	9.8 Critique	RCE — exécution de code à distance	Avril 2024
CVE-2024-21412	SmartScreen	8.1 Élevé	Bypass — contournement des protections	Février 2024
CVE-2023-23397	Outlook / NTLM	9.8 Critique	Relay NTLM — vol de hash de mot de passe	Mars 2023

Action : appliquer les **Patch Tuesday** (mises à jour mensuelles de Microsoft) via WSUS chaque mois. Ne pas laisser un serveur sans mise à jour depuis plus de 3 mois. Désactiver **NTLMv1** via GPO et activer le **SMB Signing** pour se protéger des attaques par relais.

05 — CE QUE J'AI APPLIQUÉ

De la veille à la pratique

- Politique de mot de passe à **12 caractères minimum** configurée dans ma situation E6 (au lieu de 8)
- **GPO blocage USB** déployée chez des clients Scalesi pour limiter les risques d'infection
- Script PowerShell d'**audit des comptes AD inactifs** proposé à l'équipe technique
- Vérification du **SMB Signing** activé sur les serveurs de fichiers déployés
- Application systématique des mises à jour via **WSUS** avant mise en production